EDJ

edjconsult.com
(202) 318-8873
you@edjconsult.com

The Premier League's New Cybersecurity Rules

166 requirements. Three deadlines. One rule that most clubs have not noticed.

Starting this season, every Premier League club must meet the League's Information Security Baselines. There are 166 requirements in 22 areas. They come into force in three phases over three years. Each club must send the League a progress report every January and a final report with evidence every April. The rules are on page 693 of a handbook that runs to more than 900 pages. Most clubs have IT vendors who can do the technical work. Few clubs have one person who owns the programme, the evidence, and the reporting to the League.

WHAT THE RULES REQUIRE

48	29	89
Phase One by 30 April 2027	**Phase Two** by 30 April 2028	**Phase Three** by 30 April 2029

AREA (APPENDIX 11)	P1	P2	P3
Risk management	2	2	5
Governance	2	1	4
Policies	1	1	1
Personnel security	2	3	2
Access & authentication	4	3	6
Assets	1	1	4
Network & internet	6	–	4
Endpoint hardening	5	–	7
Anti-malware	6	–	4
Email	5	–	2
Patching & vulnerabilities	1	3	2
Data retention	–	1	3
Data classification & loss prevention	2	2	5
Internet of Things	2	3	5
Backups	2	1	2
Assurance	1	2	4
Incident response	3	1	6
Cyber insurance	–	2	1
Third party / vendor	–	2	7
Accreditation	–	–	3
Protective monitoring	2	1	10
Audit	1	–	2
Total	**48**	**29**	**89**

Source: Premier League Handbook 2026/27, Rules J.9 to J.14 (pages 172 to 174) and Appendix 11, Premier League Information Security Baselines (pages 693 to 713). EDJ counted the requirements from the published rules.

THE YEARLY CYCLE

Every season, with no end date (Rules J.10 to J.12):

10 Jan — Club sends the League a progress report

› **+28 days** — If not compliant, club sends a detailed plan to fix the gaps

› **30 Apr** — Club sends a final report **with evidence**

The League can ask for more information and evidence at any time. A breach is handled under the League's general disciplinary rules. The League Board can fine a club up to £100,000 or refer the case to an independent commission.

THE RULE MOST CLUBS HAVE NOT NOTICED

- **Control 22.b (Phase One).** Each club must agree an audit plan with a **third-party auditor** for an independent security assessment **each season**. This is required from April 2027.
- **Controls 20.a to 20.c (Phase Three).** Each club must choose a recognised security framework, get executive approval for it, and have a third party audit the club against it on a regular basis.

PHASE ONE VS. PHASE THREE

PHASE ONE · 48 CONTROLS

Technical controls: EDR, MFA, firewalls, network segmentation, email security, immutable backups, an incident response plan. An IT provider can do most of this work.

PHASE THREE · 89 CONTROLS

Programme management: risk appetite, measuring whether controls work, vendor risk with KPIs, mature security monitoring, a three-year security strategy. An IT provider does not own this work. Someone at the club must.

Promoted clubs must catch up

Under Rule J.14, a club promoted after this season must meet every phase that has already passed, by the next deadline. The Handbook gives this example: a club promoted for 2027/28 must meet Phase One **and** Phase Two by 30 April 2028.

Why EDJ

EDJ gives technology leadership to regulated organisations that have vendors but no one who owns the programme. We have run this same model for US defence contractors under NIST 800-171 and CMMC: phased control frameworks, yearly evidence cycles, and remediation plans. We lead the programme. We do not run your systems and we do not sell software.

Rules J.9 to J.14 • Appendix 11 • 22 areas • 166 requirements • 10 Jan progress report • 30 Apr evidence • Three phases to 2029

Schedule a conversation.

No sales pitch. We tell you where your club stands against Phase One and what the January report will ask of you.

edjconsult.com
you@edjconsult.com
(202) 318-8873